DATAOPS

SOC | NOC | VAPT

INNOVATION HACKATHON

AI Agent for Automated Penetration Testing

Final Participant Problem Statement | AI-Powered Unified VAPT Agent

1. Background

Penetration testing involves several stages, including reconnaissance, attack-surface discovery, scanning, enumeration, vulnerability analysis, validation, and reporting.

These stages typically require multiple tools and substantial manual correlation. Cybersecurity analysts may spend more time combining and interpreting outputs from different tools than actually analyzing security risks.

This challenge aims to address this problem by developing a **context-aware, adaptive, and evidence-driven AI agent** that reduces the manual workload involved in penetration testing.

2. Problem Statement

Design and build a **conversational AI agent that guides an authorized security assessment from initial reconnaissance through the generation of a client-ready VAPT report.**

Similar to an AI research assistant that selects appropriate information sources, interprets their results, and synthesizes meaningful answers, the proposed agent must be capable of:

- Selecting appropriate cybersecurity tools based on the assessment requirements.
- Interpreting scan results and identifying potential vulnerabilities.
- Deciding what needs to be investigated next.
- Correlating evidence obtained from multiple security tools.
- Prioritizing identified risks.
- Explaining its decisions and the reasoning behind its actions.

The agent must demonstrate actual security reasoning rather than blindly executing a predefined sequence of scanners.

Important Security Boundary:

All live testing must remain strictly within organizer-provided and explicitly authorized sandbox/lab targets.

Active exploitation or offensive proof-of-concept validation requires explicit human approval before execution.

---

3. Expected User Experience and End-to-End Workflow

The AI agent should support the following end-to-end assessment workflow:

Analyst Request → Agent Planning → Approved Scan Orchestration → Result Ingestion → AI Analysis → Risk Prioritization → Human Review → Unified VAPT Report

The workflow should include:

1. **Analyst Request:** Accept a natural-language assessment request along with the authorized target and scope.
2. **Agent Planning:** Generate an assessment plan by selecting appropriate tools based on the target and explaining the rationale behind each selection.
3. **Approved Scan Orchestration:** Execute the approved security scans using the selected tools.
4. **Result Ingestion:** Collect and process the outputs generated by the integrated security tools.
5. **AI Correlation and Analysis:** Correlate findings from multiple tools and perform evidence-based analysis.
6. **Risk Prioritization:** Evaluate identified vulnerabilities and prioritize them based on their associated risks.
7. **Human Review and Approved Validation:** Allow an analyst to review findings and explicitly approve any active validation.
8. **Professional Reporting:** Generate a unified, professional VAPT report suitable for client delivery.

The agent should also:

- Display assessment progress, tool execution status, key decisions, and failures.
- Explain why a particular subsequent scan or investigation is necessary.
- Avoid unnecessary or repeated actions.
- Clearly distinguish between observed evidence and AI-generated inferences.

---

4. Tool Integration Scope

The AI agent is expected to integrate with the following cybersecurity tools:

Tool	Primary Expected Role
Nmap	Host, port, and service discovery; reconnaissance and enumeration.
Nessus	Infrastructure vulnerability assessment and finding import/API integration.
OpenVAS / Greenbone	Infrastructure vulnerability assessment and result correlation.
Nikto	Web server configuration and known-issue checks.
OWASP ZAP	Web application and API security scanning.
Burp Suite	Web testing and analyst-assisted validation; API/export integration where available.
Metasploit	Human-approved, lab-only controlled validation; never autonomous exploitation.

Integration Requirements:

- Integrations may use supported APIs, CLI interfaces, or native result imports.
- Teams must clearly disclose which integrations execute live scans and which only import recorded outputs.
- Commercial tool availability and licensing must not be misrepresented.

---

5. Functional Requirements

The proposed AI agent must demonstrate the following functional capabilities:

5.1 Scope Enforcement

Register approved lab targets, exclusions, permissions, and scan boundaries. The agent must reject any actions that fall outside the authorized scope.

5.2 Adaptive Planning

Select relevant tools based on discovered hosts, services, technologies, and previously obtained results. The agent must explain the rationale behind its next steps.

5.3 Scan Orchestration

Execute permitted scans, monitor running jobs, handle timeouts and errors, and maintain records of tool execution status.

5.4 Normalization and Correlation

Map findings obtained from different tools into a common data model. Merge genuine duplicate findings without hiding distinct affected assets or supporting evidence.

5.5 Evidence and Validation

Preserve the following information for identified findings:

- Source tool.
- Affected asset.
- Timestamps.
- Raw references.
- Supporting evidence.
- Confidence level.
- Confirmed or suspected status.

5.6 Risk Prioritization

Evaluate vulnerabilities by considering:

- Severity and CVSS.
- Exposure.
- Exploitability.
- Asset impact.
- Confidence level.

The agent must not generate fabricated CVEs, proof, or risk scores.

5.7 Human-in-the-Loop

Require explicit human approval before performing any active exploitation or offensive validation. The approval and its outcome must be recorded.

5.8 Reporting

Generate a readable, client-ready VAPT report containing executive and technical views, remediation recommendations, and assessment limitations.

---

6. Minimum Demonstrable Prototype vs. Advanced Extensions

Participants must distinguish between the mandatory capabilities required for a working prototype and additional advanced features.

Mandatory for Working Prototype	Advanced / Bonus Features
Conversational request, scope validation, and auditable plan.	Multi-step adaptive replanning with state/memory.
At least three working tool integrations or supported imports, including network and web coverage.	All seven tool adapters with reliable live/API support where legally available.
Common finding schema, evidence links, duplicate handling, and risk ranking.	Confidence calibration, advanced false-positive triage, and remediation tracking.
Professional downloadable PDF report and analyst approval gate.	Retesting, change comparison, export formats, and team workflows.

Integration Transparency:

Teams should document a truthful integration matrix for all seven named tools, identifying each integration as:

- Live.
- Import-only.
- Planned.
- Unsupported.

A recorded demonstration is not a substitute for showing which actions actually execute.

---

7. Professional VAPT Report – Required Sections

The generated VAPT report must contain the following sections:

7.1 Executive Summary

- Executive summary and overall assessment scope.

7.2 Assessment Methodology

- Methodology.
- Rules of engagement.
- Assets tested.
- Tool execution summary.

7.3 Severity Distribution

- Severity distribution.
- Prioritized findings.

7.4 Detailed Vulnerability Findings

For each identified finding, include:

- Finding identifier.
- Affected asset.
- Description.
- Severity/CVSS (if supported).
- CVE/CWE (if applicable).
- Supporting evidence.
- Confidence level.
- Validation status.

7.5 Impact and Remediation

- Business and technical impact.
- Actionable remediation recommendations.
- References.

7.6 Assessment Limitations

- Testing limitations.
- Assumptions.
- Scan failures.
- Human approvals.
- Assessment timestamps.

---

8. Standards and Reference Frameworks

Participants should use the following standards and reference frameworks, wherever applicable:

1. NIST SP 800-115.
2. OWASP Top 10.
3. Common Vulnerabilities and Exposures (CVE).
4. Common Vulnerability Scoring System (CVSS).

5. Common Weakness Enumeration (CWE).
6. MITRE ATT&CK.
7. NIST Cybersecurity Framework (CSF) 2.0.

Note: Using these standards and frameworks does not, by itself, establish formal compliance with them.

---

9. Required Deliverables

Participating teams must submit and demonstrate the following:

9.1 Working AI Agent / Prototype

A functional AI agent or prototype demonstrated against an organizer-authorized sample lab target.

9.2 Architecture Overview

An overview covering:

- AI model(s).
- Orchestration.
- Tool adapters.
- Data flow.
- State/memory.
- Security boundaries.

9.3 Sample VAPT Report

A sample AI-generated, evidence-backed VAPT report in PDF format.

9.4 Source Repository

A source code repository containing:

- Setup instructions.
- Dependencies.
- Licensing assumptions.
- Execution instructions.

9.5 Human-Approval Demonstration

A demonstration of the human-approval mechanism for active validation, along with a decision/audit trace documenting actions and their outcomes.

9.6 Integration Status Matrix

A documented integration status matrix covering:

- Known limitations.
- Assumptions.
- Unsupported scenarios.

---

10. Judges' Live Demonstration Checklist

During the final demonstration, judges will evaluate the following capabilities:

1. Enter an authorized target and conversational assessment request, and demonstrate scope validation.
2. Show the AI agent generating an assessment plan with clear tool selections and reasoning.
3. Execute or import multi-tool assessments, displaying genuine tool execution status and traceable outputs.
4. Demonstrate normalization, cross-tool correlation, duplicate/false-positive handling, and uncertainty.
5. Demonstrate severity/risk prioritization and an explicit human-approval checkpoint before any active validation.
6. Download and inspect the final unified VAPT report, tracing a reported finding back to its original source evidence.
7. Demonstrate safe failure handling and honestly identify unsupported integrations.

---

11. Judging Criteria (100 Points)

The proposed solutions will be evaluated based on the following criteria:

Evaluation Criterion	Points	What Judges Assess
End-to-End Coverage	15	Coherent reconnaissance-to-report workflow.
AI Reasoning & Decisions	20	Adaptive planning, contextual next steps, and rationale.
Technical Accuracy	15	Correct interpretation, evidence, and validation status.
Correlation & False Positives	15	Deduplication, confidence, and traceability.
Risk Prioritization	10	Defensible severity, impact, and exposure ranking.
Safety & Scope Control	10	Lab-only scope, approval, and audit trail.
Report Quality	10	Professional clarity, evidence, and remediation.
Efficiency & Robustness	5	Avoidance of unnecessary actions and recovery from errors.
TOTAL	**100**	

---

12. Near-Perfect Solution Characteristics

A high-quality solution should demonstrate the following characteristics:

- High lifecycle coverage.
- Evidence-based adaptive reasoning.
- Low false-positive rate.
- Strong cross-tool correlation.
- Defensible risk prioritization.

- Complete evidence traceability.
- Strict scope enforcement.
- Mandatory human approval for active actions.
- Transparent uncertainty.
- Efficient execution.
- Graceful failure recovery.
- A professional and technically accurate report.

---

13. Safety, Ethics and Assessment Integrity

Participants must adhere to the following security and ethical requirements throughout the assessment:

- Do not test third-party or public systems.
- Do not evade authorization.
- Do not perform uncontrolled exploitation.
- Do not fabricate scanner output.
- Respect organizer-provided lab boundaries, rate limits, and credentials.
- Store sensitive scan data securely.
- Ensure that LLM-generated conclusions are grounded in actual tool evidence.
- Ensure every action is attributable through an audit trail.

Success Criterion

Judges should see a working AI security assistant that reduces manual coordination and reporting effort while keeping the human analyst in control of consequential actions.